

Lumi Reading · Security & Privacy Evidence

A7

Access Register (Privileged / Operator)

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

FIRST REVIEW 2026-07-24 · SIGNATURE PENDING

ST4S item: A7 (access review / revocation) **Related:** A6/A13 (access control — [ACCESS_CONTROL_POLICY.md](#)), HR1/HR3 ([HR_SECURITY_PACK.md](#)), A10 ([DEVICE_STANDARD.md](#)) **Version:** 1.0 · **Date:** 2026-07-24 **Status:** Populated · first review performed 2026-07-24 · MFA confirmation + signature pending

1. Purpose and scope
- The access register is the single authoritative list of **who has access to which system, at what level, and when that access was last reviewed**. It is the driving artefact for A7 (periodic access review) and for HR offboarding ([HR_SECURITY_PACK.md](#)) §4 — a leaver's rows are exactly what must be revoked). [ACCESS_CONTROL_POLICY.md](#) §9 names this register as a required standing document.
- Scope: every **human** principal (today: the director; on engagement: any contractor or adviser) against every system that can reach Lumi code, the production project, or student data. Application end-users (parents, teachers, school admins) are **not** in this register — their access is governed server-side by the security rules and membership documents ([ACCESS_CONTROL_POLICY.md](#)) §2–3) and reviewed through the membership/rollover cadence, not here. This register is the **privileged / operator** access list.
- Data-minimisation note.** No passwords, tokens, keys, MFA seeds, or personal identifiers appear here — the register records *that* access exists and its level, never the credential itself. Those live in the password manager / secret store.

2. Current principals

#	Person (named)	Role	Screening (HR1)	Device (A10)
1	Nicholas Plevritis	Founder / Director — Security Lead (GO1) & Privacy Officer (GO2); sole operator	Current WWCC held — verified 2026-07-24 (detail in restricted HR file)	Primary workstation on the device register (DEVICE_STANDARD.md) §4)

Single-principal estate. Any contractor/adviser who later gains access is added as a new principal here **after** HR1 screening + HR2 training + device standard are met, at least privilege for their role.

3. Register — matrix form (one row per person; cell = access level, "—" = none)

Person	GCP/Firebase lumi-ninc-au	GitHub	Apple Dev	Google Play	School portal	Super-admin portal	Mailboxes	Domain registrar	Cloudflare	Password mgr	MFA on all?	Last reviewed
Nicholas Plevritis	Owner	Org-Owner	Account-Holder	Account-Owner	super-admin	super-admin (MFA-enforced)	Owner	Account-Owner	Account-Owner	Owner	 confirm (see §5)	2026-07-24

4. Register — per-system detail (authoritative long form)

One row per (person × system) with justification, MFA, and the review action.

Person	System	Access level	Business justification (least-privilege test)	MFA enforced?	Date granted	Last reviewed	Reviewer	Action
Nic	GCP / Firebase lumi-ninc-au	Owner	Sole operator of the production project; no other principal to delegate to	 confirm	Project inception	2026-07-24	N. Plevritis	keep
Nic	GitHub (repo/org)	Org-Owner	Sole maintainer; owns CI/CD + deploy trust	 confirm	Repo inception	2026-07-24	N. Plevritis	keep

Person	System	Access level	Business justification (least-privilege test)	MFA enforced?	Date granted	Last reviewed	Reviewer	Action
Nic	Apple Developer / App Store Connect	Account-Holder	Sole publisher of the iOS app	🔒 confirm	Enrolment	2026-07-24	N. Plevritis	keep
Nic	Google Play Console	Account-Owner	Sole publisher of the Android app	🔒 confirm	Enrolment	2026-07-24	N. Plevritis	keep
Nic	School admin portal (<code>school-admin-web</code>)	super-admin	Operational support for schools	inherits portal MFA	Portal launch	2026-07-24	N. Plevritis	keep
Nic	Super-admin portal (<code>admin/</code>)	super-admin (<code>/superAdmins/{uid}</code>)	Cross-tenant Lumi operations	enforced (admin TOTP, <code>ACCESS_CONTROL_POLICY.md</code> §6)	Portal launch	2026-07-24	N. Plevritis	keep
Nic	Support / admin mailboxes	Owner	Owns <code>support@</code> + demo/review mailboxes	🔒 confirm	Setup	2026-07-24	N. Plevritis	keep
Nic	Domain registrar	Account-Owner	Owns the domain + DNS of record	🔒 confirm	Domain purchase	2026-07-24	N. Plevritis	keep
Nic	Cloudflare (edge / status worker)	Account-Owner	Owns the status-banner worker + any edge/DNS	🔒 confirm	Worker setup	2026-07-24	N. Plevritis	keep
Nic	Password manager	Owner	Custody of all secrets + recovery keys	🔒 confirm	Setup	2026-07-24	N. Plevritis	keep

Vendors without a human console login (server-to-server sub-processors) are tracked in `SUB_PROCESSOR_TABLE.md`, not here. Any vendor console a human logs into (e.g. billing entity portal, error/analytics tooling) is added as a row above when adopted.

5. First review — findings (2026-07-24)

Reviewer: Nicholas Plevritis · **Date:** 2026-07-24 · **Scope:** all rows in §4.

- All access is appropriate and at the minimum feasible level for a single-operator estate.** With one principal, every system's least-privilege baseline is owner/holder — there is no second principal to reduce against, so every row's action is **keep**. No excess or stale grants found; no unknown principals.
- One open action — MFA confirmation (🔒).** MFA is **confirmed enforced** on the super-admin portal (admin TOTP). For the remaining consoles marked "🔒 confirm" (GCP/Firebase Google account, GitHub, Apple, Google Play, mailboxes, domain registrar, Cloudflare, password manager) Nic must **log in and confirm 2FA is on**, then change each "🔒 confirm" to "enforced" and countersign. This is the only item preventing this register from being complete A7 evidence.
- Improvement (not a finding).** Best practice even for a sole operator is to use a least-privilege day-to-day identity and reserve Owner for break-glass; adopt this at the point a second principal joins (tracked in `ACCESS_CONTROL_POLICY.md`).

6. Review cadence (A7)

Trigger	Action	Frequency
Annual review	Walk every row: confirm the person still needs the access at that level; reduce to least privilege or revoke; confirm MFA; stamp "date last reviewed" and reviewer	Annual (next due 2027-07-24)
On role change	Grant/reduce access for the new role same-day; add/adjust rows	On change
On joiner	Add rows only after HR1 screening + HR2 training + device standard met; default least privilege	On event
On leaver / for-cause	Revoke every row same-day (immediately if malicious) per <code>HR_SECURITY_PACK.md</code> §4; the register is the checklist	On event
Monthly IAM spot-check	The GCP/Firebase IAM + deploy-identity subset is reviewed monthly (<code>ACCESS_CONTROL_POLICY.md</code> §8); reconcile findings back into this register	Monthly (IAM subset)

The **annual full-register review** is the A7 evidence: a dated pass (this §5 being the first) where every row's "last reviewed" is stamped and each access is confirmed keep/reduce/revoke by a named reviewer.

7. Relationship to other controls

- **Access control policy.** The server-side application access model and the monthly IAM / privileged-session cadence live in `ACCESS_CONTROL_POLICY.md` §8; this register is the *human/operator* companion it §9 requires.
- **HR pack.** Screening (HR1) and offboarding (HR3) are driven from this register (`HR_SECURITY_PACK.md`).
- **Device standard.** Adding a person usually adds a device; keep the device register (`DEVICE_STANDARD.md` §4) in step with joiner/leaver events here.

8. Sign-off

First review performed and register populated by: **Nicholas Plevritis** Signature: _____ Date: 2026-07-24

Open before final sign-off: complete the MFA confirmations in §5 item 2 (change each "🔒 confirm" to "enforced"). Once done, this register is complete A7 evidence.